

Escenario

Una organización necesita compartir documentos sensibles entre empleados que se conectan mediante una red que no es confiable.

Se debe asumir que un atacante puede:

- Capturar el tráfico.
- Modificar mensajes.
- Reenviar comunicaciones anteriores.
- Suplantar usuarios.
- Robar archivos almacenados en el servidor.
- Intentar adivinar contraseñas.
- Obtener acceso al código fuente de la aplicación.

El sistema debe proteger, como mínimo:

- Confidencialidad.
- Integridad.
- Autenticidad.
- Protección contra repetición.
- Seguridad de credenciales y llaves.

Funcionalidades obligatorias

A. Gestión de usuarios

El sistema debe permitir:

1. Registrar usuarios.
2. Iniciar sesión.
3. Almacenar las contraseñas de forma segura.
4. Generar un par de llaves para cada usuario.
5. Asociar cada llave pública con su propietario.
6. Proteger la llave privada.

Las contraseñas no deben guardarse con SHA-256 directo. Deben utilizar una función apropiada como:

- Argon2.
- scrypt.
- PBKDF2.

Con una sal única por usuario.

Cifrado de archivos o mensajes

El contenido debe cifrarse utilizando un algoritmo simétrico moderno:

- AES-GCM.
- ChaCha20-Poly1305.

No permitiría ECB ni CBC sin autenticación.

El sistema debe:

- Generar una llave simétrica nueva para cada archivo o sesión.
- Generar correctamente el nonce o IV.
- Cifrar el contenido.
- Generar y validar la etiqueta de autenticación.
- Rechazar el mensaje cuando la validación falle.

Protección de la llave de sesión

La llave simétrica debe protegerse utilizando criptografía asimétrica o un mecanismo de establecimiento de llaves.

Opciones:

- RSA-OAEP.
- ECDH.
- X25519.
- Intercambio de llaves autenticado.

Por ejemplo:

1. Alice genera una llave AES.

2. Cifra el archivo con AES-GCM.
3. Protege la llave AES con la llave pública de Bob.
4. Bob utiliza su llave privada para recuperar la llave AES.
5. Bob descifra el archivo.

Firma digital

El emisor deberá firmar el archivo o mensaje.

Pueden utilizar:

- RSA-PSS.
- ECDSA.
- Ed25519.

El receptor debe poder comprobar:

- Que el archivo fue enviado por el usuario esperado.
- Que no fue modificado.
- Que la firma es válida.

Deben distinguir claramente entre:

- Cifrar.
- Firmar.
- Verificar una firma.
- Validar la etiqueta de autenticación.

Protección contra ataques de repetición

Cada mensaje debe incluir elementos como:

- Identificador único.
- Número de secuencia.
- Timestamp.
- Nonce del protocolo.

El receptor debe detectar cuando un atacante intenta volver a enviar un mensaje previamente válido.

Registro de eventos

El sistema debe generar logs sobre:

- Inicio de sesión.
- Envío de archivos.
- Recepción.
- Firma válida o inválida.
- Error de autenticación.
- Intento de repetición.
- Fallo al descifrar.
- Llave o certificado desconocido.

Los logs no deben contener:

- Contraseñas.
- Llaves privadas.
- Llaves de sesión.
- Contenido completo de mensajes sensibles.

Requisitos de seguridad

Se debe demostrar que su proyecto cumple con las siguientes reglas:

1. No inventar algoritmos criptográficos propios para proteger información real.
2. Utilizar bibliotecas criptográficas reconocidas.
3. No reutilizar nonces cuando el algoritmo lo prohíba.
4. No incluir llaves directamente en el código.
5. No almacenar contraseñas en texto claro.
6. No utilizar MD5 o SHA-1 como mecanismos de seguridad.
7. No utilizar RSA sin padding seguro.
8. No cifrar directamente archivos grandes con RSA.
9. No confiar únicamente en ocultar el código.

10. Validar errores sin revelar información sensible.

Pueden implementar algoritmos pequeños desde cero únicamente con fines didácticos, pero no para la parte funcional del sistema.

Componente matemático obligatorio

Se debe explicar matemáticamente al menos dos mecanismos.

Por ejemplo:

RSA

- Generación de números primos.
- Cálculo de n .
- Función phi.
- Selección de e .
- Cálculo del inverso d .
- Exponenciación modular.
- Por qué la versión real necesita padding.

Diffie-Hellman o ECDH

- Secreto compartido.
- Exponenciación modular o multiplicación escalar.
- Problema del logaritmo discreto.
- Necesidad de autenticación.
- Riesgo de ataque de intermediario.

AES

No necesitan desarrollar toda la prueba matemática, pero sí explicar:

- Bloques.
- Rondas.
- Sustitución.
- Permutación.
- Confusión.

- Difusión.
- Papel del modo GCM.

Hash y firmas

- Por qué se firma normalmente el hash y no todo el archivo.
- Resistencia a colisiones.
- Resistencia a preimagen.
- Efecto avalancha.

Componente de seguridad de redes

El proyecto debe incluir una captura y análisis en Wireshark.

Se deben demostrar:

1. Qué datos pueden observarse en la red.
2. Qué información permanece cifrada.
3. Qué metadatos siguen siendo visibles.
4. Qué ocurre cuando se modifica un paquete o archivo.
5. Qué sucede cuando se reenvía un mensaje anterior.
6. Qué cambia si la comunicación también utiliza TLS.
7. La diferencia entre cifrado de transporte y cifrado de extremo a extremo.

Modelo de amenazas

Se debe entregar un modelo de amenazas sencillo

Debe incluir:

Elemento	Ejemplos
Activos	Archivos, contraseñas, llaves privadas, identidades
Adversarios	Atacante externo, usuario interno, servidor comprometido
Capacidades	Capturar, modificar, repetir, robar archivos

Elemento	Ejemplos
Objetivos	Leer archivos, suplantar, modificar órdenes
Controles	Cifrado, firmas, autenticación, logs
Riesgos residuales	Endpoint comprometido, robo de llave privada

También se debe indicar explícitamente qué amenazas quedan fuera del alcance.

Ataques que deben demostrar

Además de mostrar que el sistema funciona, se debe intentar atacarlo.

Ataque 1: modificación del archivo

Modificar algunos bytes del texto cifrado.

Resultado esperado:

- La autenticación debe fallar.
- El archivo no debe entregarse como válido.

Ataque 2: firma falsa

Intentar verificar el archivo con una llave pública distinta.

Resultado esperado:

- Firma inválida.

Ataque 3: repetición

Enviar dos veces el mismo paquete.

Resultado esperado:

- El segundo intento debe rechazarse.

Ataque 4: contraseña incorrecta

Intentar iniciar sesión repetidamente.

Resultado esperado:

- Rechazo.
- Registro del evento.

- Idealmente, limitación de intentos.

Ataque 5: robo de la base de datos

Mostrar qué información obtendría un atacante si roba la base de datos.

Deben explicar:

- Por qué no aparecen contraseñas en texto claro.
- Qué podría intentar hacer con los hashes.
- Qué información pública podría conocer.
- Qué datos seguirían siendo sensibles.

Ataque 6: intermediario

Si utilizan Diffie-Hellman sin autenticación, demostrar un ataque MITM conceptual o práctico.

Después deben explicar cómo evitarlo mediante:

- Firmas.
- Certificados.
- Llaves públicas verificadas.
- Canal autenticado.

Parte postcuántica

Se debe responder:

1. ¿Qué partes del sistema serían vulnerables ante una computadora cuántica suficientemente potente?
2. ¿Qué partes seguirían siendo razonablemente seguras?
3. ¿Cómo sustituirían RSA, ECDH o ECC?
4. ¿Qué diferencia existe entre ML-KEM y ML-DSA?
5. ¿Qué significa migración híbrida?
6. ¿Qué es “harvest now, decrypt later”?
7. ¿Qué cambios serían necesarios para lograr criptoagilidad?